QCon
全球软件开发大会
上海 2026

InfoQ 极客传媒

AI 驱动
复杂业务漏洞挖掘

从业务规则建模到攻击路径验证

于思　　字节跳动 安全攻防专家



演讲目录

01 业务漏洞挖掘挑战

02 业务语义理解

03 端到端攻击路径验证

04 实践经验分享

01 业务漏洞挖掘挑战

传统扫描为什么难发现业务漏洞

传统 Web 漏洞

SQL 注入　XSS　命令注入　文件读取

替换参数，测试 Payload

SQL 注入

```
GET /product?id=123
↓
  GET /product?id=' OR '1'='1
```

XSS

```
GET /search?q=phone
↓
  q=<script>alert(1)</script>
```

核验响应差异、脚本执行等缺陷特征

复杂业务漏洞

业务规则：关闭后仅本人可见

用户 A：对外展示我的数据　关闭

用户 B 查询用户 A 的数据

```
GET /user/data?user_id=A
```

↓

```
200 OK        仍返回用户 A 的数据
```

识别风险，需要先理解这条展示规则

请求成功 ≠ 业务行为符合预期

常见的业务安全风险

业务风险

核心商业数据爬取

商品价格 / 经营数据

可见范围 / 批量获取边界

营销资损

优惠券 / 补贴 / 积分

参与资格 / 叠加及结算规则

羊毛黄牛

新客权益 / 限购抢购

身份关联 / 参与次数 / 配额

可能涉及的漏洞和利用方式

越权

逻辑漏洞

并发漏洞

组合利用

做安全测试，先理解业务

一次风险挖掘

- **理解业务**
- 准备条件
- 研究和测试
- 报告和复测

交叉核对业务规则

PRD	使用角色、允许的操作、业务例外
技术方案	对象流转、状态变化、调用前提
业务代码	校验位置、关键分支、权限边界
接口定义	输入条件、参数含义、返回数据

02 业务语义理解

AI 怎么理解一个 API

AI 找到的材料（脱敏重构示意）

接口流量片段

```
POST /after-sale/detail
{"shop": "A",
 "order": "A"}

200 OK
{"amount": "***",
 "recipient": "***"}
```

关联需求 / 技术方案摘录

客服查询售后单

角色：商家客服

范围：已授权店铺

只读：金额、收货信息

后端代码（示意伪代码）

```
def detail(ctx, req):
    check_role(ctx, "support")
    order = load(req.order)
    check_shop(ctx, order.shop)
    return fields(order,
      "amount", "recipient")
```

AI 查找入口

Path → 业务文档

服务归属 → 后端代码

业务线 / 需求 → PRD / 技术方案

AI 交叉分析后的画像

售后单详情查询

只读查询

使用方

商家客服

输入对象

店铺 / 订单

返回数据

金额 / 收货信息

权限预期

客服岗位 + 授权店铺

怎么找到相关的业务接口

AI 归纳的功能、使用角色、关键输入，成为资产检索的入口

按业务功能查找

功能搜索

购物车

相关功能接口	功能示意
加入购物车	创建
修改商品数量	修改
删除购物车商品	删除

组合画像条件

使用角色 **消费者**

关键输入 **优惠券参数**

符合条件的候选接口	结果示意
订单优惠试算	消费者
关键输入 优惠券标识	
提交订单	消费者
关键输入 已选优惠券	

先圈定相关接口，再分析业务关系

AI 怎么提出假设、设计实验

结合业务上下文和历史经验

角色、对象、接口关系和状态

→

AI 提出可检验的攻击假设

改什么、保持什么、预期有什么不同

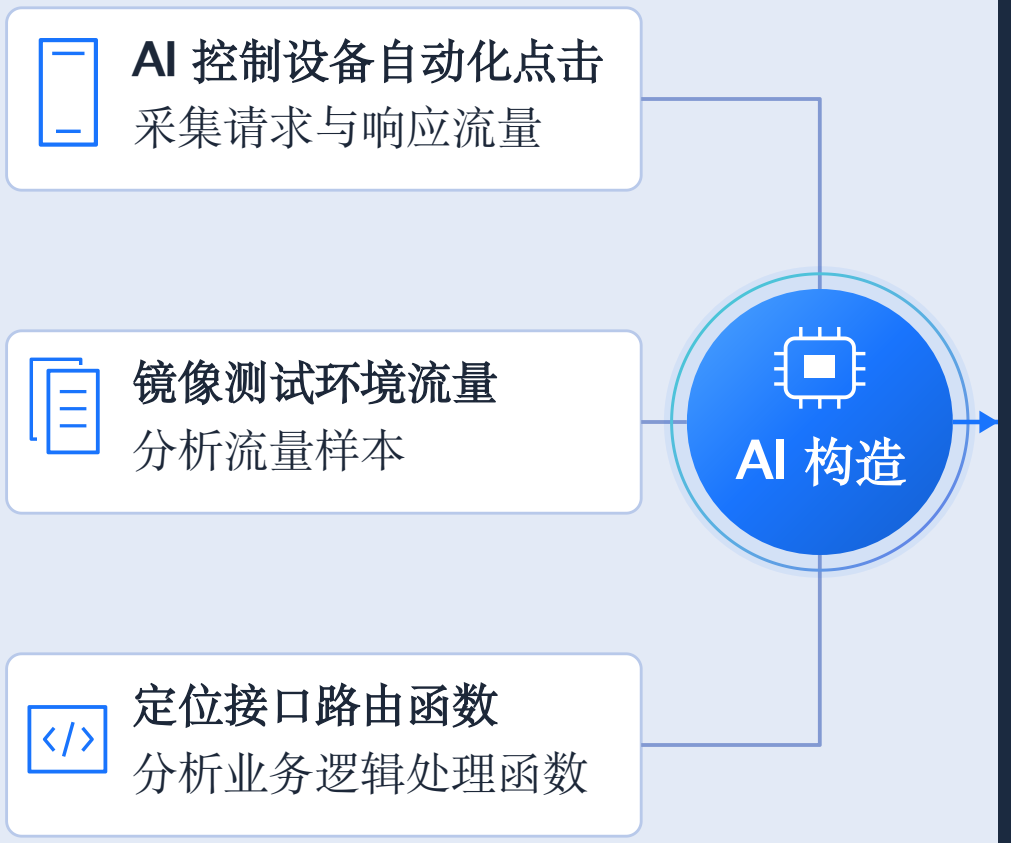
四组差分实验的基本设计

实验分组	条件怎么设	这一组要回答什么
正常业务（D）	使用正常身份、有效物料和请求	正常业务能否成功完成？
保护基线（A）	设置按业务规则应受限的条件	原本的业务限制是否生效？
待测实验（B）	保持受限条件，只加入待测变化	与 A 比较：限制是否失效？
对照复验（C）	撤销待测变化，恢复可比初始状态	与 B 比较：异常是否随改动消失？

03 端到端攻击路径验证

怎么构造正确的业务请求

AI 结合线上设备触发的流量、测试环境流量和业务代码，构造业务请求



订单金额试算（虚构示意）

```
POST /checkout/quote HTTP/1.1
Host: api.example.com
Content-Type: application/json
Authorization: Bearer [REDACTED_SECRET]
X-Client: mobile
Accept: application/json

{
  "cart_id": "CART_DEMO",
  "items": [
    {"sku_id":"SKU_DEMO_01","quantity":2},
    {"sku_id":"SKU_DEMO_02","quantity":1}
  ],
  "discounts": {"coupon_ids":["COUPON_DEMO"]},
  "delivery": {
    "address_ref":"ADDR_DEMO",
    "shipping_option":"standard"
  },
  "context": {"currency":"XXX","channel":"app"},
  "quote_token":"[DYNAMIC_VALUE]"
}
```

把日常工具和数据封装成 Skill

围绕任务目标，整理人工测试使用的数据入口和工具



端到端的攻击任务

任务目标、实验计划、目标接口请求

AI 按执行反馈继续查证

运行四组实验

- **D** 正常业务
- **A** 保护基线
- **B** 待测实验
- **C** 对照复验

账号、关联物料、区域出口

正常组没有取得目标数据

01 查询同次请求日志

核对处理过程和数据状态

02 查相关接口和业务代码

定位对象关系、缺失的前置条件

03 AI 调整执行步骤

补齐前置操作，保持实验变量

重跑原组，继续核验

交付可复核结论

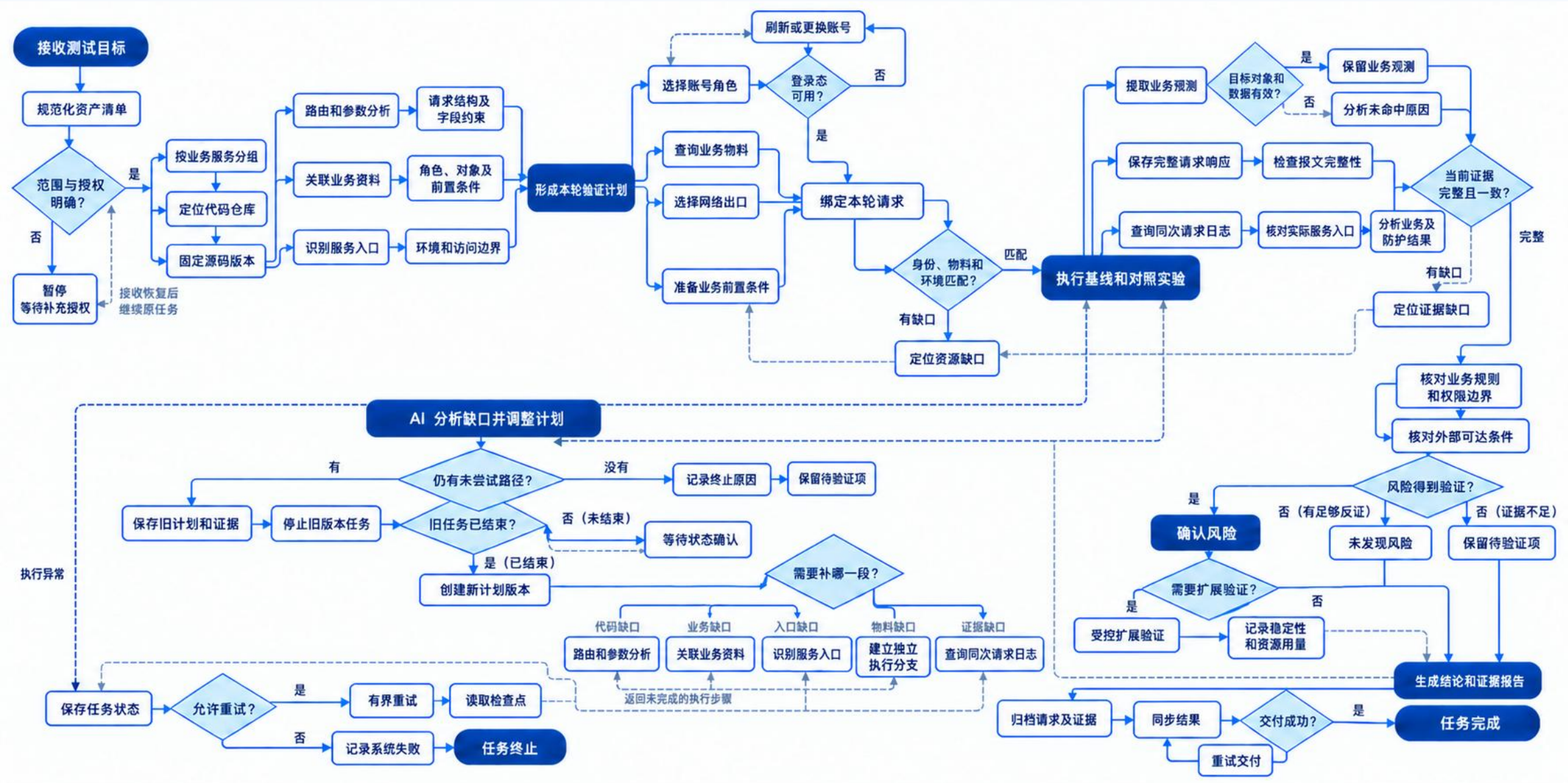
对照结果
业务影响
归因证据

风险成立

本轮未发现风险

条件不足，记录缺口

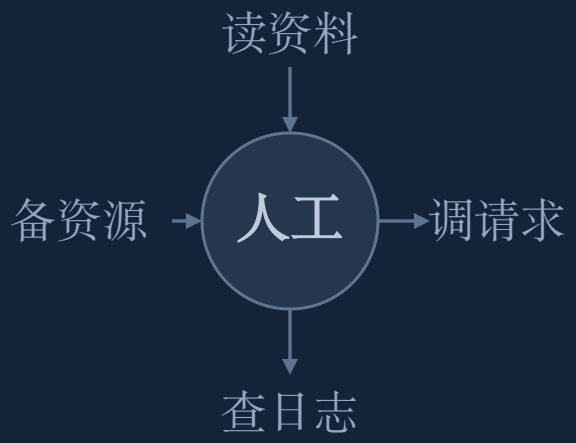
AI 驱动的端到端测试流程图



接口测试已经交给大模型

过去

人串联每一步



逐接口操作、判断、整理

现在

AI 承接整项测试任务

全量资产业务分析

结合代码补齐接口信息

AI 端到端执行

理解接口 → 执行实验 → 归因验证

安全同学

研究新手法，建设工具
处理复杂问题

交付结果

数百个

核心商业数据风险

已经验证

- ✓ 复现请求
- ✓ 业务影响
- ✓ 日志归因

04 实践经验分享

AI 负责推理，程序负责确定性执行

把已经验证的操作方法固定下来

模型推进整项任务

规划验证路径

解释异常和差异

判断证据与下一步

程序稳定执行

请求执行	参数装配、按计划发包
结果处理	字段解析、结果提取和去重
证据保存	请求、响应、日志和执行条件
执行方式	脚本、固定动作、局部 Workflow

按资产持续沉淀

分析记录、请求结构、脚本、适用条件、证据

下次任务先读取、核对，再复用

攻防经验单独维护，AI 按需读取

攻防知识库

人工整理、复核、持续更新

历史 Case	数据可见性开关失效
专家经验	如何确认越权，排除误判
验证手法	角色切换、授权前后对照

人来阅读学习

按专题浏览 · 复盘历史 Case

AI 按任务加载

Skill　按场景、关键词读取

适用条件 · 经验做法 · 验证要点
带入本轮分析和实验设计

仅更新经验 → Harness / Workflow 无需修改

基建决定能验证多少场景



覆盖关系示意

攻击假设需要完整验证

能否构造有效请求?

能否取得匹配的资源?

能否调用工具并核验结果?

Skill	原子工具	数据入口	测试账号	业务物料	网络代理
任务方法	实际操作	业务上下文	角色、权限	对象、状态	地区、环境

风险结论要有黑盒证据

白盒分析定位疑点

经营报表导出（示意）

```
@require_login
def export_report(user, req):
    report = load(req.report_id)
    rows = query_rows(report)
    return build_file(rows)
```

这里只看到了登录校验

对象归属、店铺权限在哪里检查？

网关、中间件和下游服务仍需核对

输出：疑点和攻击假设

黑盒验证风险是否成立

账号身份	能登录的业务账号、对照身份
网络环境	匹配地区、终端和代理出口
业务物料	关联对象、归属和前置状态
有效请求	请求结构、有效参数值、动态凭证

跑通正常业务 → 执行对照实验 → 确认业务影响

输出：可复现的风险证据

AiCon 北京站

全球人工智能开发与应用大会

探索 AI 应用边界

Explore the limits of AI applications

2026 年 12 月 18–19 日 / 北京新云南皇冠假日酒店

参会咨询

专题：Post-Training Engineering | 数据、奖励与模型能力塑造



专题出品人：余瑶

飞猪 / 资深算法专家

专题：大模型推理与算力调度实践



专题出品人：范苑

阿里云 / 专有云计算产品负责人

专题：Knowledge Engineering | 让 Agent 理解企业



专题出品人：盛茂家

火山引擎 / Viking 团队技术负责人

专题：Loop & Graph Engineering



专题出品人：孙子荀

腾讯 / 腾讯高级总监

专题：AI 原生架构的演进与治理



专题出品人：刘中兵

快手 / 架构治理团队 & AI 架构演进负责人

专题：Agentic Software Engineering | 从代码生成到软件交付



专题出品人：杨杰

荣耀 / 首席 IT 技术架构师

让 AI 完成整项安全任务

让 AI 直接使用知识、平台和工具

承担从业务理解到风险验证的完整任务

AI 推进整项任务	理解业务，提出假设 执行实验，根据反馈调整
团队持续积累能力	固化操作，保留资产上下文 独立维护专家经验，补齐测试基础

基础建设决定覆盖面，黑盒证据支撑风险结论

谢谢

Q&A